

How to Set Up a Hardened WordPress Server on Ubuntu 24.04

A practical guide to a production-ready web server with CIS hardening and STRIDE analysis by Patrik K, IT-Security Specialist, TUC Yrkeshögskola Stockholm

Preface

This assignment demonstrates both the value and limitations of post-deployment hardening. Starting from a baseline Lynis score of 65, hardening measures were implemented systematically across all STRIDE threat categories, reaching a final score of 71. While this modest improvement might appear underwhelming, it reveals an important principle: many security gains require architectural decisions made at installation time rather than patches applied after deployment.

The work undertaken produced measurable security improvements. However, these gains are not reflected in the Lynis scoring algorithm, as much as one would hope, which weights low-level configuration checks that typically require architectural decisions at installation time. This project therefore illustrates why "secure by design" is not merely a principle but a practical necessity.

The approach follows 5 phases:

1. Baseline Measurement
2. Installation of CSM
3. Hardening Measures
4. Post-Hardening Measurement
5. Comparison and Analysis

Phase 1: Baseline Measurement

Before any hardening was performed, after setting up the Ubuntu VM, a security baseline was established using Lynis and a custom measurement script "security_check_log.sh" that collects five key metrics: Lynis score, open network ports, available security updates, number of sudo users, and number of active services. The purpose being to get a picture of where we are at the outset so that we can more easily observe results from hardening techniques over the course of this assignment.

```
patrik@patrik-Virtual-Machine:/usr/local/bin$ sudo security_check_log.sh
=====
Linux Härdningsrapport
=====
Datum: 2026-03-09 14:40:06
Lynis Security Score: 65
Öppna portar (LISTEN): 4
Tillgängliga uppdateringar: 18
Sudo-användare: 1
Aktiva tjänster: 31
=====
Rapport sparad i: security_log.csv
```

Baseline results:

- Lynis score: 65

- Open ports: 4
- Available updates: 18
- Sudo users: 1
- Active services: 31

Phase 2: Content Management System (CSM) Installation

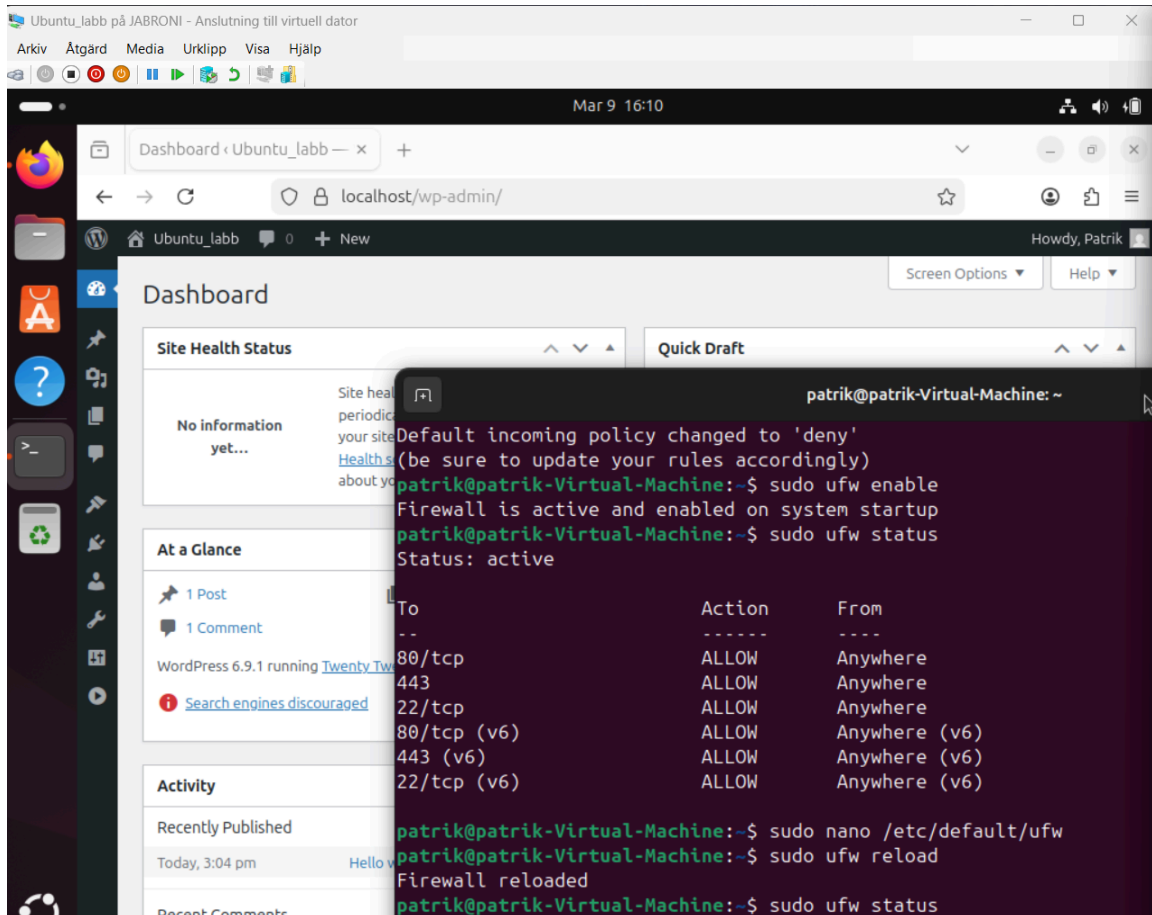
However, before beginning with this phase, running a general apt upgrade and apt update command will update latest versions of installed packets. Also, in my case, curl and SSH had to be installed as well upon discovering that they weren't already installed by default.

The web server stack was installed with three components:

- Apache2 as the web server that handles HTTP/HTTPS requests,
- MariaDB as the database, and
- PHP as the scripting language that connects them and runs Wordpress code.

A dedicated MariaDB database named "wordpress" was created alongside a database user "wpuser" with restricted privileges following the principle of least privilege by granting access only to the WordPress database. WordPress was downloaded directly from wordpress.org, unzipped, and its configuration file "wp-config.php" was updated with the database credentials. The WordPress files were moved to Apache's web root at "/var/www/html/" and ownership was transferred to "www-data" which is Apache's own system identity on the server. Apache requires file ownership to read and write; without this transfer, Apache cannot access the WordPress installation.

SSL/TLS encryption was configured using mkcert, which generates locally-trusted certificates without requiring a public domain. The generated certificate and private key were placed in "/etc/ssl/mkcert/" and Apache's SSL configuration was updated to reference them, replacing the default placeholder certificates. Apache's SSL module and HTTPS site configuration were then activated and reloaded, encrypting all traffic over HTTPS on port 443.



Phase 3: Hardening Measures

STRIDE Methodology

The hardening phase was structured around the STRIDE threat model to ensure systematic coverage of all major attack categories rather than implementing random security measures. It is one thing following ready-made techniques from an instructor and another approaching hardening from contemplating which categories deserve adequate attention. Essentially, STRIDE allows you to intentionally and proactively search for threats and controls.

STRIDE is a threat modeling framework developed by Microsoft. It covers six threat categories: Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, and Elevation of Privilege. STRIDE served as the framework for selecting and justifying each hardening measure, ensuring coverage of realistic threats against a Linux-based WordPress server. The aim is to research and implement at least one control per category and map it against a CIS benchmark (which included the instructor's solutions but only after mapping them against STRIDE).

CIS Benchmarks are internationally recognized security configuration guidelines developed by the Center for Internet Security, widely adopted as the practical standard for demonstrating compliance with broader frameworks and regulations including ISO 27001, NIST CSF, PCI-DSS, and GDPR Article 32.

Hardening Measures per STRIDE Category

Spoofing attacks involve impersonating legitimate users or services. SSH hardening addressed this by disabling root login (CIS 5.1.20) and moving the service to port 2222 (non-CIS good practice) which reduces exposure to automated scanning. Fail2ban was configured to ban IPs after 3 failed login attempts within 5 minutes for 24 hours (non-CIS good practice).

Tampering controls prevent unauthorized modification of software and data. Apt package sources were switched to HTTPS (CIS 1.2.1.2) to prevent man-in-the-middle attacks during downloads. Package verification was enforced to block installation from unsigned repositories (CIS 1.2.1.1), and the openssl version was pinned to prevent unintended updates to a critical cryptographic component (non-CIS good practice).

Repudiation is where a user or attacker denies having performed an action and was addressed by installing and enabling auditd (CIS 6.2.1.1 and CIS 6.2.1.2), which creates a tamper-evident log of all privileged system activity. Every sudo command, session open, and credential use is recorded with timestamp, user, and result. Additionally, rkhunter was installed and run as a baseline integrity check which scanned 498 known rootkit signatures and returned zero threats, thus confirming the system had not been compromised during the setup phase.

Information Disclosure is where sensitive data is exposed to unauthorized parties and was addressed by configuring the uncomplicated firewall (UFW) to block all incoming traffic by default (CIS 4.2.1.7) and allowing only HTTPS (443) and SSH (2222). HTTP (port 80) was explicitly removed to prevent unencrypted access. IPv6 was disabled since the server operates in a local IPv4-only environment (CIS 3.1.1).

Denial of Service is where an attacker overwhelms a system to make it unavailable to legitimate users. Here, it is addressed at two layers: the network layer (OSI 3/4), UFW rate limiting blocks IPs exceeding 6 new connections per 30 seconds (CIS 4.2.1.7); the application layer (OSI 7), Fail2ban bans repeat login offenders (*non-CIS supplementary hardening - see Spoofing note above*), Wordfence protects WordPress against web-based attacks, and XML-RPC was disabled to eliminate a known DDoS amplification vector (CIS Apache HTTP Server Benchmark 2.6).

Elevation of Privilege controls limit attacker access escalation. Root SSH login was disabled (CIS 5.1.20), automatic security updates enabled via unattended-upgrades (CIS 1.2.2.1), and unused packages removed to reduce the number of potential privilege escalation entry points (CIS 2.1). Also, unnecessary system services were removed, for example: avahi-daemon (CIS 2.1.2), cups (CIS 2.1.6), cups-browsed (CIS 2.1.6), gnome-remote-desktop, kerneloops, ModemManager, switcheroo-control, and rtkit-daemon. In this context, each of these represent either an unnecessary network exposure or a background process with no justified role on a production WordPress server which directly impacts attack surface (CIS 2.1).

Uncomplicated Firewall (UFW) Configuration

UFW is configured as the system's network-level defense. The default policy should be to deny all incoming traffic, meaning only explicitly allowed services can receive connections. HTTPS (443) allows for WordPress traffic and SSH (2222) allows for remote administration. Here, HTTP (port 80) was deliberately excluded towards the end of this configuration to prevent unencrypted access and to make sure the other connections were working. Also, IPv6 was disabled since the server operates in a local IPv4-only environment (CIS 3.1.1) which removes an unnecessary network attack surface. Rate limiting was applied to the SSH port which blocks any IP that attempts more than 6 new connections within 30 seconds and which complements Fail2ban's application-layer protection with a network-layer defense.

```
patrik@patrik-Virtual-Machine:~$ sudo ufw status
[sudo] password for patrik:
Status: active

To Action From
--
443 ALLOW Anywhere
2222/tcp LIMIT Anywhere

patrik@patrik-Virtual-Machine:~$
```

New Lynis scan for comparison:

```
patrik@patrik-Virtual-Machine:~$ sudo security_check_log.sh
=====
Linux Härdningsrapport
=====
Datum: 2026-03-09 18:45:25
Lynis Security Score: 68
Öppna portar (LISTEN): 7
Tillgängliga uppdateringar: 2
Sudo-användare: 1
Aktiva tjänster: 28
=====
Rapport sparad i: security_log.csv
```

Service Review

All running services were reviewed to minimize attack surface. Unnecessary services on a production WordPress server were disabled: avahi-daemon (local network discovery), cups and cups-browsed (printing), gnome-remote-desktop (remote desktop access), kerneloops (kernel crash reporting to external servers), ModemManager (mobile modem management), switcheroo-control (GPU switching), and rtkit-daemon (realtime audio scheduling). The remaining active services are all directly required for the WordPress stack, system logging, authentication, or security monitoring.

Rkhunter Output:

```
System checks summary
=====

File properties checks...
  Files checked: 144
  Suspect files: 1

Rootkit checks...
  Rootkits checked : 498
  Possible rootkits: 0

Applications checks...
  All checks skipped

The system checks took: 3 minutes and 23 seconds

All results have been written to the log file: /var/log/rkhunter.log

One or more warnings have been found while checking the system.
Please check the log file (/var/log/rkhunter.log)
```

Lynus Score Progression thus far:

```
patrik@patrik-Virtual-Machine:~$ cat ~/security_log.csv
Datum,Lynis Score,Öppna portar,Antal uppdateringar,Sudo-användare,Aktiva tjänster
2026-03-09 14:27:26,:,4,18,1,31
2026-03-09 18:15:51,68,9,2,1,36
2026-03-09 18:45:25,68,7,2,1,28
```

Additional Hardening Measures

Following the initial STRIDE-based hardening which reached a score of 68, surely we can bump up the score so additional measures were implemented to target areas Lynis weights heavily in its scoring. These controls address remaining attack vectors not covered by initial hardening.

Kernel parameter hardening via `/etc/sysctl.conf` (CIS 3.3.1, 3.3.2, 1.5.3) addressed Spoofing, Denial of Service, and Information Disclosure. IP forwarding and source routing were disabled to prevent spoofing. SYN cookies were enabled (CIS 3.3.10) to protect against SYN flood DoS attacks. Core dumps were restricted (CIS 1.5.3) to prevent sensitive memory from being written to disk. Bogus ICMP error responses were ignored (CIS 3.3.6) to reduce network attack exposure.

PAM password quality enforcement via `libpam-pwquality` (CIS 5.3.2.1-5.3.2.8) targeted Elevation of Privilege by making brute force and credential-based attacks harder.

AIDE (Advanced Intrusion Detection Environment) was installed and initialized (CIS 6.3.1) to create a cryptographic baseline of all system files. Unauthorized modifications can be detected by comparing against this baseline, addressing Repudiation and Tampering in STRIDE.

Default file creation permissions were tightened by changing the system umask from 022 to 027 (CIS 5.4.3.3) which ensures that newly created files are not readable by unauthorized users by default. This is a least privilege control targeting Information Disclosure at the filesystem level.

```
patrik@patrik-Virtual-Machine:~$ sudo security_check_log.sh
[sudo] password for patrik:
=====
Linux Hårdningsrapport
=====
Datum: 2026-03-10 12:40:06
Lynis Security Score: 71
Öppna portar (LISTEN): 7
Tillgängliga uppdateringar: 2
Sudo-användare: 1
Aktiva tjänster: 28
=====
Rapport sparad i: security_log.csv
patrik@patrik-Virtual-Machine:~$
```

Phase 4: Post-Hardening Measurement

```
patrik@patrik-Virtual-Machine:~$ cat ~/security_log.csv
Datum,Lynis Score,Öppna portar,Antal uppdateringar,Sudo-användare,Aktiva tjänster
2026-03-09 14:27:26,:,4,18,1,31
2026-03-09 18:15:51,68,9,2,1,36
2026-03-09 18:45:25,68,7,2,1,28
2026-03-09 19:57:58,70,7,2,1,29
2026-03-09 20:54:42,70,7,2,1,29
2026-03-10 12:40:06,71,7,2,1,28
patrik@patrik-Virtual-Machine:~$
```

Phase 5: Comparison and Analysis

Lynis Over Time

The initial measurement had a parsing error in the measurement script, but after correction, a baseline of 65 was established. Following hardening measures and a system reboot, the score reached 71 which underscores the necessity to restart a system for some changes to take full effect. In this case, changes to the kernel `/etc/sysctl.conf` and disabling of a service. Available updates decreased from 18 to 2, reflecting apt upgrade and activation of unattended-upgrades. Open ports increased from 4 to 7 due to the installation of Apache, SSH on port 2222, and MariaDB. See results below

Measurement	Lynis	Ports	Updates	Services
Baseline	65	4	18	31
Post-hardening	71	7	2	28

OpenSCAP: CIS and STIG Compliance

OpenSCAP evaluates systems against established security benchmarks and generates compliance reports, providing more detailed standards-based assessment than Lynis alone. Running it against three different profiles, CIS Level 1 achieved 60.3% and is the most relevant result for a production system of this type. The majority of failures relate to architectural requirements beyond the scope of this system. CIS Level 2 and STIG scored 50.8% and 52.3% respectively with STIG's higher score explained by its narrower scope rather than strictness. See results and screenshots below:

Profile	Score	Passed Rules
CIS Level 1	60.3%	231/368
CIS Level 2	50.8%	243/470
STIG	52.3%	58/220

Evaluation Characteristics

Evaluation target	patrik-Virtual-Machine
Benchmark URL	#scap_org.open-scap_comp_ssg-ubuntu2404-xccdf.xml
Benchmark ID	xccdf_org.ssgproject.content_benchmark_UBUNTU_24-04
Benchmark version	0.1.80
Profile ID	xccdf_org.ssgproject.content_profile_cis_level1_server
Started at	2026-03-10T14:02:44+01:00
Finished at	2026-03-10T14:03:16+01:00
Performed by	patrik
Test system	cpe:/a:redhat:openscap:1.3.9

CIS Level 1:

Compliance and Scoring

The target system did not satisfy the conditions of 125 rules! Furthermore, the results of 12 rules were inconclusive. Please review rule results and consider applying remediation.

Rule results



Severity of failed rules



Score

Scoring system	Score	Maximum	Percent
urn:xccdf:scoring:default	60.305855	100.000000	60.31%

CIS Level 2:

Compliance and Scoring

The target system did not satisfy the conditions of 213 rules! Furthermore, the results of 14 rules were inconclusive. Please review rule results and consider applying remediation.

Rule results



Severity of failed rules



Score

Scoring system	Score	Maximum	Percent
urn:xccdf:scoring:default	50.799313	100.000000	50.8%

STIG:

Compliance and Scoring

The target system did not satisfy the conditions of 157 rules! Furthermore, the results of 5 rules were inconclusive. Please review rule results and consider applying remediation.

Rule results



Severity of failed rules



Score

Scoring system	Score	Maximum	Percent
urn:xccdf:scoring:default	52.328129	100.000000	52.33%

Conclusion

The system achieves a solid security level for a production environment of this type. The remaining deficiencies are predominantly architectural and would have to be addressed during the system design phase rather than retrospectively. This reflects a core principle: security is built in from design, not applied after deployment. Based on the OpenSCAP findings, continued improvement would require revisiting the system design with such things as separate disk partitions, AppArmor profiles for Apache and MariaDB, and a more granular sudo configuration. However, all of these are better addressed at installation time than “patched” onto a running system.

The modest Lynis score improvement from 65 to 71 reflects a difference between what Lynis measures and what was implemented. Lynis rewards specific low-level configuration checks like kernel module restrictions, PAM stack details, compiler availability, and mount options. Many of which require architectural-level decisions made at installation time. The OpenSCAP reports confirm this. The hardening improved security measurably: fewer services, fewer updates, stronger authentication. These gains are not fully reflected in the Lynis algorithm. It is also worth noting that STIG (52.3%) scored higher than CIS Level 2 (50.8%), which is explained by scope differences rather than strictness and its focus on specific DoD

configurations.

The initial STRIDE based hardening addressed primary attack vectors (credential attacks via SSH, tampering during package updates, and accountability through auditd), but the additional kernel and filesystem hardening measures (sysctl parameters, AIDE, PAM enforcement) ultimately drove the score improvement. This shows a gap between practical security impact and measurement. Practical security and Lynis scores measure different things.